



UNIT 2

ORGANIZATION SECURITY AND CONTROLS

ORGANIZATION SECURITY AND CONTROLS

- Organization Security and Controls are the coordinated efforts, processes, and governance mechanisms an organization implements to manage security risks, enforce policies, and ensure compliance with laws and standards.

Components of Organization Security and Controls:

1. Security Governance

- Defines roles and responsibilities for security within the organization.
- Establishes security policies, procedures, and standards.
- Examples

ORGANIZATION SECURITY AND CONTROLS

- Creating a security committee or appointing a Chief Information Security Officer (CISO).
- Developing and enforcing an information security policy.

2. Risk Management

- Identifying, assessing, and mitigating security risks.
- Conducting risk assessments regularly.
- Implementing controls to reduce risks to an acceptable level.

ORGANIZATION SECURITY AND CONTROLS

3. Access Controls

- Defining who can access what resources and when.
- Includes authentication (passwords, biometrics) and authorization (permissions).
- Examples:
 - Role-based access control (RBAC).
 - Physical and logical access restrictions.

4. Security Awareness and Training

- Educating employees about security risks.
- Regular training to recognize phishing, social engineering, and safe data handling.

ORGANIZATION SECURITY AND CONTROLS

5. Incident Response

- Preparing for and managing security breaches or incidents.
- Having defined procedures to detect, report, respond to, and recover from incidents.

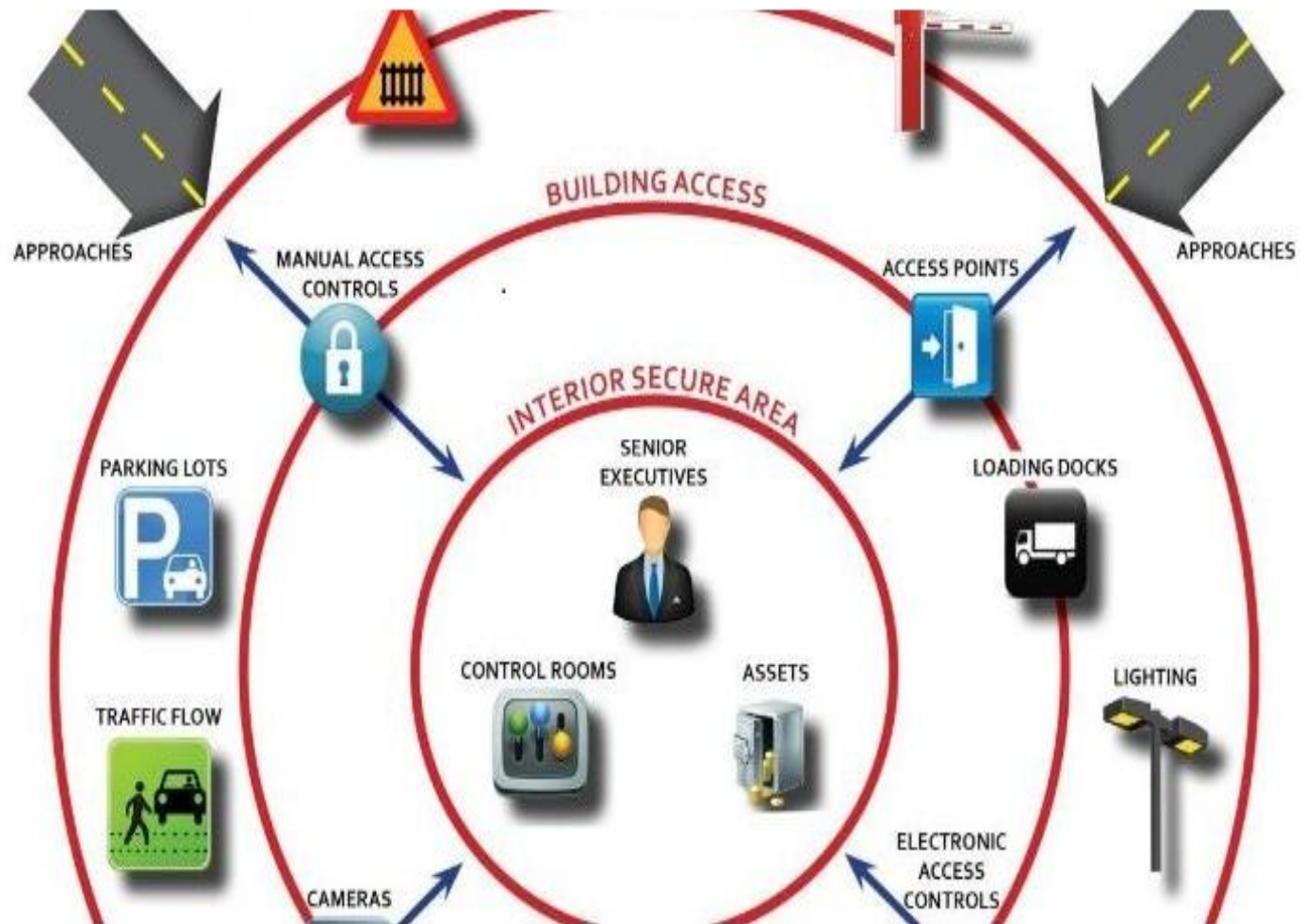
6. Physical Security Controls (covered earlier)

- Protecting the physical environment and assets.

7. Compliance and Auditing

- Ensuring the organization meets relevant legal, regulatory, and contractual requirements.
- Performing regular audits and reviews to ensure controls are effective.

Physical Security



LAYERS OF PHYSICAL SECURITY

1. Deterrence

- The goal of Deterrence methods is to convince a potential attacker that a successful attack is not possible due to strong defenses.
- For example: By placing your keys inside a highly secure key control system made up of heavy metal like steel, you can help prevent attackers from gaining access to assets.
- Deterrence methods are classified into 4 categories:
- **Physical Barriers:** These include fences, walls, vehicle barriers, etc. They also act as a Psychological deterrent by defining the perimeter of the facility and making intrusion seem more difficult.

LAYERS OF PHYSICAL SECURITY

- **Combination Barriers:** These are designed to defeat defined threats. This is a part of building codes as well as fire codes.
- **Natural Surveillance:** In this architects seek to build places that are more open and visible to authorized users and security personnel so that attackers are unable to perform the unauthorized activity without being seen.
- **Security Lighting:** Doors, gates or other means of the entrance should be well lit as Intruders are less likely to enter well-lit areas. Keep mind to place lighting in a manner, that is difficult to tamper.

LAYERS OF PHYSICAL SECURITY

2. Detection

➤ Alarm Systems and Sensors:

Alarm systems can be installed to alert security personnel in case of an attempt of unauthorized access. They consist of sensors like perimeter sensors, motion sensors, etc.

➤ Video Surveillance:

Surveillance cameras can be used for detection if an attack has already occurred and a camera is placed at the point of attack. Recorded video can be used

LAYERS OF PHYSICAL SECURITY

3. Access Control

- These methods are used to monitor and control the traffic through specific access points. Access Control includes the following methods:
- **Mechanical Access Control Systems:** These includes gates, doors, locks, etc.
- **Electronic Access Control:** These are used to monitor and control larger populations, controlling for user life cycles, dates and individual access points.
- **Identification System and access policies:** These includes the use of policies, procedures and processes to manage the access into the restricted area.

LAYERS OF PHYSICAL SECURITY

4. Security Personnel

- They play a central role in all layers of security. They perform many functions like:
- Administering electronic access control.
- Responding to alarms.
- Monitoring and analyzing video footage and many more

Contingency Plan (Physical Security)

- A contingency plan, also known as a backup plan or Plan B, is a pre-defined set of actions to be taken in response to unexpected events that could disrupt a project or business.
- It's a way to prepare for and mitigate potential risks, ensuring that operations can continue or be resumed as quickly as possible.

PURPOSE OF A CONTINGENCY PLAN

- The main purpose of a contingency plan in project management is to help an organization maintain its operations or get back to its operations quickly and easily after an unforeseen occurrence.



PURPOSE OF A CONTINGENCY PLAN

1. Better preparation:

- It's possible to protect your organization from several risky scenarios through preemptive and efficient planning. For example, there is a possibility to lose the on-premise data backup in a fire. But you can be prepared if you have a contingency plan like taking the backup of your data in the cloud.

2. Quicker solution:

- A business responds quickly to unfavorable situations if they have a contingency plan in project management. This helps them to overcome the problem without much damage to their regular operations.

PURPOSE OF A CONTINGENCY PLAN

3.To prevent panic:

- More than the danger, what causes more panic and disaster is the feeling that there is no solution. However, if you have contingency plans, everyone in the organization knows that a plan of action is there to quickly overcome the situation. This allows fast recovery even in the worst cases, thus, also bringing down the panic.

4.To minimize losses:

- In case of any disruption, whether a power outage, natural disaster, or even shifting of office space, a contingency plan can help the business minimize the

PURPOSE OF A CONTINGENCY PLAN

losses in production and sales. The major difference between a business that collapses in disaster and the one that survives is the plans that allow them to get their production back on track even after any unforeseen circumstances.

A CONTINGENCY PLAN

HOW TO PREPARE CONTINGENCY PLAN FOR BUSINESS



A CONTINGENCY PLAN

1. Identify the risks:

- For what disasters you are preparing for is important to know before you preparing for it. So, start by thinking about every possible risk that your organization may face.
- This may include natural disasters, security threats, or sudden changes to personnel or revenue.
- It's better to involve individuals from different teams or departments to cover the risks that might come to the whole organization and not only your department.

A CONTINGENCY PLAN

2. Prioritizing the risk:

- Firstly, you need to determine the risks that are most likely to occur in your organization. As we know, every business is unique in its own way, so there is no single plan that will fit all businesses.
- Instead, you need to make the plan based on the nature and requirements of your business. Start by answering the questions below before writing a contingency plan:
 1. What may happen?
 2. What to do in response to the problem?
 3. What can be done to prepare in advance?

A CONTINGENCY PLAN

- While writing and developing a contingency plan, make sure to spend both resources and time to prepare for the events that have a high possibility of occurring.
- For example, if you have earthquakes listed as a possible risk but your area doesn't have many instances of earthquakes, then spending all your time to prepare for it is not required. But if you have a flood-prone area, you should prioritize the risk and spend more resources to prepare for floods.

A CONTINGENCY PLAN

3. Write contingency plan:

- After creating a prioritized list, you need to develop a plan for mitigating those risks. Include a step-by-step guide and visuals in your contingency plan that outlines the things to do when the event happens and how to still keep your organization running in that situation.
- Also, include a list of people from both outside and inside the organization to contact if any event occurs. You can also list out ways to minimize the risk from those events and start to act on it now.

A CONTINGENCY PLAN

4.Ensure maintaining the plan:

- The process doesn't stop even after you have prepared a contingency plan. You need to communicate the contingency plan to everyone in the organization who might have the potential to get affected.
- Their roles and responsibilities during the time of crisis also need to be described to them. Also, review the plan from time to time as any technological, operational, and personnel changes can make your plan inefficient. So, you regularly need to make the necessary changes.

DISASTER RECOVERY



Disaster Recovery ?

DISASTER RECOVERY

Disaster recovery

- Disaster recovery (DR) is an organization's ability to respond to and recover from an event that negatively affects business operations.
- The goal of DR methods is to enable the organization to regain use of critical systems and IT infrastructure as soon as possible after a disaster occurs.
- To prepare for this, organizations often perform an in-depth analysis of their systems and create a formal document to follow in times. This document is known as a disaster recovery plan.

DISASTER RECOVERY

Types of disaster include:

- Cyber attacks such as malware, DDoS and ransomware attacks
- Power outages
- Equipment failure
- Epidemics or pandemics, such as COVID-19
- Terrorist attacks or threats
- Industrial accidents
- Earthquakes
- Floods
- Fires

DISASTER RECOVERY

importance of disaster recovery

- Disasters can inflict many types of damage with varying levels of severity, depending on the scenario.
- A brief network outage could result in frustrated customers and some loss of business to an e-commerce system.
- A hurricane or tornado could destroy an entire manufacturing facility, data center or office.

DISASTER RECOVERY

Disaster Recovery Plan



DISASTER RECOVERY

The components of a DR plan should include:

- A DR policy statement, plan overview and main goals of the plan.
- Key personnel and DR team contact information.
- A step-by-step description of disaster response actions immediately following an incident.
- A diagram of the entire network and recovery site.
- Directions for how to reach the recovery site.
- A list of software and systems that staff will use in the recovery.

DISASTER RECOVERY

- Sample templates for a variety of technology recoveries, including technical documentation from vendors.
- A communication that includes internal and external contacts, as well as boilerplate for dealing with the media.
- Summary of insurance coverage.
- Proposed actions for dealing with financial and legal issues

DISASTER RECOVERY

Disaster recovery sites

- An organization uses a DR site to recover and restore its data, technology infrastructure and operations when its primary data center is unavailable
- DR sites can be internal, external or cloud-based.
- An organization sets up and maintains an internal DR site.
- Organizations with large information requirements is most likely to use an internal DR site, which is typically a second data center.

DISASTER RECOVERY

- An external disaster recovery site is owned and operated by a third-party provider.

- External sites can be hot, warm or cold.

1.Hot site: A fully functional data center with hardware and software, personnel and customer data, which is typically staffed around the clock and operationally ready in the event of a disaster.

2.Warm site: An equipped data center that doesn't have customer data; an organization can install additional equipment and introduce customer data following a disaster.

DISASTER RECOVERY

3.Cold site: Has infrastructure to support IT systems and data, but no technology until an organization activates DR plans and installs equipment; they are sometimes used to supplement hot and warm sites during a long-term disaster.

DISASTER RECOVERY

Data center disaster recovery

- Organizations that house their own data centers must have a DR strategy that considers all the IT infrastructure within the data center as well as the physical facility.
- Backup to a failover site at a secondary data center facility is often a large part of the plan
- IT and business leaders should also document and make alternative arrangements for a wide range of facilities-related components including power systems, heating and cooling, fire safety and physical security.

DISASTER RECOVERY

Network disaster recovery

- Network connectivity is essential for internal and external communication, data sharing and application access during a disaster.
- A network DR strategy must provide a plan for restoring network services, especially in terms of access to backup sites and data.

DISASTER RECOVERY

Virtualized disaster recovery

- Virtualization enables DR by allowing organizations to replicate workloads in an alternate location or the cloud.
- The benefits of virtual DR include flexibility, ease of implementation, efficiency and speed.
- Virtualized workloads have a small IT footprint, replication can be done frequently, and failover can be initiated quickly. Several data protection vendors offer virtual backup and DR as a product.

DISASTER RECOVERY

Cloud disaster recovery

- The widespread acceptance of cloud services allows organizations that traditionally used an alternate location for DR to be hosted in the cloud.
- Cloud DR goes beyond simple backup to the cloud.
- It requires an IT team to set up automatic failover of workloads to a public cloud platform in the event of a disruption.

DISASTER RECOVERY

Disaster recovery as a service (DRaaS)

- DRaaS is the commercially available version of cloud DR. In DRaaS, a third party provides replication and hosting of an organization's physical and virtual servers.
- The provider assumes responsibility for implementing the DR plan when a crisis arises, based on a service-level agreement



2.2 LOGICAL SECURITY CONTROLS

2.2.1 OPERATING SYSTEM SECURITY AND ACCESS CONTROL

LOGICAL SECURITY CONTROLS

- Logical security controls are technical measures that control access to and protect digital assets within a system or network.
- Examples include firewalls, access control lists (ACLs), encryption, intrusion detection systems (IDS), and strong authentication methods like passwords and multi-factor authentication (MFA).

LOGICAL SECURITY CONTROLS

- Logical controls that can prevent access to an organizations informational asset include :
Authentication of unauthorized users from being permitted to access a company's systems

1) **User identification** (e.g. username and passwords)

2) **Password management:**

- Passwords are generated to protect access from outside, unwanted users of information.
- This is a method that is applied to only enabling access to those who are authorized. Passwords have certain characteristics that will allow them to become more preventative than

LOGICAL SECURITY CONTROLS

- others. they are at least eight characters long; every character added to this minimum makes the password exponentially safer.
 - They include a variety of uppercase and lowercase letters, numbers, and symbols.
 - They do not include real names and words
- 3) **Network firewalls:** Parts of computer systems or networks that are designed to block unauthorized access while permitting outward communication.
- 4) **Data encryption:** A security method that applies information that is encoded and can only be accessed or decrypted by a user with the correct encryption key.

LOGICAL SECURITY CONTROLS

- Encrypted data will also sometimes appear scrambled or unreadable to a person or entity accessing it without permission.

5) **Access control lists:**

- Tables that tell a computer operating system who has the right to access it. Rights vary per user and allows them to have a particular objective (e.g. accessing a file directory or individual file).

6) **Digital certificates:**

- A digital certificate is an electronic “password” that allows a person, organization to exchange data securely over the internet using the public key infrastructure (PKI).

LOGICAL SECURITY CONTROLS

- A computer is a combination of physical and logical systems, security practices must address both of these sides of computing.

1. Active Directory

- **Active Directory** is a Microsoft solution for managing users, computers, and information access in a network.
- It is based on a database of all resources and users that will be managed within the network.
- The information in the database determines what people can see and do within the network.

LOGICAL SECURITY CONTROLS

- **Login script:** When a user logs onto the network, Active Directory knows who that user is and runs a login script to make the assigned resources available. Examples of login tasks include virus updates, drive mapping, and printer assignments.
- **Domain:** The domain is a computer network or group of computer networks under one administration. Users log into the Active Directory domain to access network resources within the domain.

LOGICAL SECURITY CONTROLS

➤ **Group Policy:**

This is a set of rules and instructions defining what a user or group of users can or cannot do when logged into the domain. You may see the term Group Policy Object (GPO), which is a set of instructions assigned to a group of users or to certain machines on the network.

➤ **Organizational Unit (OU):**

OUs are logical groups that help organize users and computers so that GPOs can be assigned to them. For example, a team of accountants may be assigned to an OU, and their GPO may give them special access to financial records.

LOGICAL SECURITY CONTROLS

➤ **Home folder:**

This folder, which is accessible to the network administrator, is where the user's data and files are kept locally.

➤ **Folder redirection:**

This allows for the work done by an OU to be saved on a common folder in the domain as directed by the administrator instead of the user.

For example, a policy may indicate that all work must be kept in a common folder so all members of a team can see the latest work and updates

LOGICAL SECURITY CONTROLS

Software Tokens

- **Software tokens** are part of a multifactor authentication process. The difference is that software tokens exist in software and are commonly stored on devices.
- An example of a software token is Google Authenticator, an app that is downloaded to a device and provides a shared secret key.
- The user logs in with his or her username and password, and the app runs an authenticating algorithm.
- This multifactor authentication is more secure than earlier versions of software tokens, which could be stolen.

LOGICAL SECURITY CONTROLS

● MDM Policies

- Organizations that have many mobile devices need to administer them such that all devices and users comply with the security practices in place.
- This is usually done with a suite of software known as mobile device management (MDM). The MDM marketplace is quite competitive, and several solutions are available from companies such as VMware (AirWatch), Citrix (XenMobile), and SOTI MobiControl.
- These products push updates and allow an administrator to configure many mobile devices from a central location

LOGICAL SECURITY CONTROLS

Port Security

- Disabling ports refers to using a firewall appliance or software firewall to prevent specified UDP or TCP ports from being used by a service, an application, a specific device, or all devices.
- Turning off unused ports makes it harder for hackers to find stealthy access into a machine.

MAC Address Filtering

- Every network adapter, whether it's built into a PC, is an add-on card, or is built into a specialized device such as a media adapter or a networked printer, has a unique identifier known as the media access control address

LOGICAL SECURITY CONTROLS

- A MAC address is usually found on a label on the side of a network adapter. If an adapter is already installed, enter **ipconfig /all** at a command prompt to display the MAC address.
- MAC address filtering can be a useful way to block casual hackers from gaining access to a small wireless (or wired) network, but it can be troublesome for a large network with many different devices coming into and going out of the system as each needs to be entered separately.

LOGICAL SECURITY CONTROLS

Multifactor Authentication

- The best type of authentication system is one that uses two or more authentication methods. This is known as multifactor authentication.
- An example of this would be a person using a smart card and typing a username and password to gain access to a system.
- The combination of the password and the physical token makes it very difficult for imposters to gain access to a system.

LOGICAL SECURITY CONTROLS

- **Directory permissions** is the term used in macOS and Linux for configuring the access levels a user has to a directory (folder) and individual files. In Windows, the equivalent term is file and folder permissions.
- In Linux and macOS, directory permissions include:
 - ✓ Read (opens file but no changes)
 - ✓ Write (able to read and change file)
 - ✓ Execute (runs executable file or opens directory)

LOGICAL SECURITY CONTROLS

- The chmod command is used in Linux to change directory permissions. In macOS, the Get Info menu's Sharing & Permissions submenu is used to change directory permissions.
- In Windows, file and folder permissions on an NTFS drive include:
 - ✓ Full control
 - ✓ Modify
 - ✓ Read & Execute
 - ✓ List folder contents (applies to folders only)
 - ✓ Read
 - ✓ Write

LOGICAL SECURITY CONTROLS

VPN

- A virtual private network (VPN) is a private and secure network connection that is carried by an insecure public network, such as the Internet.
- A VPN connection requires a VPN server at the remote site and a VPN client at the client site. VPN traffic between client and server is encrypted and encapsulated into packets suitable for transmission over the network. VPNs can be used in place of leased lines for connections between locations and for telecommuting workers.

LOGICAL SECURITY CONTROLS

- The most common types of VPNs use Point-to-Point Tunneling Protocol (PPTP) and Layer 2 Tunneling Protocol (L2TP/IPsec).

Access Control Lists

- **Access control lists (ACLs)** are lists of permissions or restriction rules for access to an object such as a file or folder.
- ACLs control which users or groups can perform specific operations on specified files or folders.

Smart Card

- Smart cards can be used to enable logins to a network, encrypt or decrypt drives, and provide digital signatures when supported by the network server.

LOGICAL SECURITY CONTROLS

Email Filtering

- Email filtering can be used to organize email into folders automatically, but from a security standpoint, its most important function is to block spam and potentially dangerous messages.
- Email filtering can be performed at the point of entry to a network with a specialized email filtering server or appliance as well as by enabling the spam and threat detection features that are built into email clients or security software.

LOGICAL SECURITY CONTROLS

- Spam or suspicious emails can be discarded or quarantined by the user, and false positives that are actually legitimate messages can be retrieved from the spam folder and placed back into the normal inbox.

EXAMPLES OF OS SECURITY

Windows OS:

- Active Directory for authentication and RBAC.
- Bit Locker for disk encryption.
- Windows Defender for malware protection.

Linux OS:

- Pluggable Authentication Modules (PAM).
- AppArmor and SELinux for MAC.
- Iptables / firewalld for network access control.

OPERATING CONTROLS

- Operating controls are internal processes and mechanisms implemented to ensure that operations are conducted securely, accurately, and in compliance with organizational policies and regulations.
- They play a crucial role in mitigating risk and preventing unauthorized activities.

OPERATING CONTROLS

Segregation of Duties (SoD)

Definition:

Segregation of Duties is a fundamental internal control that divides responsibilities among different individuals to reduce the risk of fraud or error.

Key Goals:

- Prevent **conflict of interest**
- Reduce the risk of **fraud, errors, or abuse**
- Increase accountability

OPERATING CONTROLS

Monitoring and Logging Controls

● Definition:

Monitoring and logging controls involve tracking system and user activity to detect suspicious behavior, ensure accountability, and support audits.

Common Tools:

- **SIEM systems** (e.g., Splunk, IBM QRadar, Elastic Stack)
- **Syslog servers**
- **Auditd (Linux), Event Viewer (Windows)**

OPERATING CONTROLS

Logging:

- Logging capabilities are implemented to detect abnormal usage within the secure zone as well as any attempts to undermine the effectiveness of controls within the secure zone.
- Messaging interface audit logs are retained for no less than 12 months and are sufficiently protected from an enterprise administrator-level compromise (for example, log files are transferred to a separate system with different system administrator credentials).

OPERATING CONTROLS

- Operator workstation, firewall and database audit logs are retained for no less than 31 days.
- **Minimum logs to be recorded include:**
 - Command line history for privileged operating system accounts on servers
 - Messaging and communication interface application and operating system logs that include details of abnormal system behavior (for example, multiple failed log-in attempts, authentication errors, changes to user groups)
 - Firewall log files
 - Database log files

OPERATING CONTROLS

● Monitoring:

- Procedures are in place to identify suspicious log-in activities into any privileged operating system or application account.
- Monitoring processes are in place to review server, application and database monitoring data either daily via human reviews or via automated monitoring with alerting.
- Monitoring processes are in place to review network monitoring data on a regular basis.
- Unusual or suspicious activity is reported for further investigation to the appropriate security team.

OPERATING CONTROLS

● Log monitoring

- Log monitoring is the process of continuously monitoring logs for specific events or patterns to identify potential issues or problems. Dev Ops and Developers continuously observe logs as they're recorded, and further, they employ log monitoring tools to collect, examine, and comprehend network performance data.
- Log monitoring is often used to ensure system stability, identify security breaches, and track changes or updates to a system. It can be used in various settings, including IT departments, web servers, and cloud-based systems.

NEED LOG MONITORING

- Log monitoring can assist companies in adhering to various laws and regulations, including GDPR, HIPAA, PCI, and many more. In addition, logs provide a cost-effective means of complying with critical regulatory requirements.
- The common activities tracked consist of
 - Login attempts to the account
 - Aspects of account management
 - Access to directory services
 - System activities
 - Alterations to policy

NEED LOG MONITORING

b) Provide faster incident response & resolution.

- Log monitoring enables teams to detect and address incidents swiftly and identify potential issues before they impact end users.

c) Enhanced security

- Programs and apps are the targets of several cyberattacks. Monitoring logs enable businesses to identify code weaknesses and take preemptive measures to boost program performance.
- Identifying weak performance areas.
- Debugging and evaluating the health of an application.

NEED LOG MONITORING

- Detecting and locating the source of installation and run-time issues in applications.

d) Improve team performance

- Through log monitoring, teams can optimize system performance by identifying possible blockages and ineffective setups.
- System health is being monitored in real-time for irregularities or inactivity.
- Detecting problems with performance or settings.
- Observe operational goals and SLAs.

NEED LOG MONITORING

e) Create a better team collaboration

- Cloud operators and architects gain from a single log monitoring solution to build more dependable multi-cloud setups.
- Teams can better react to events rapidly and identify issues before they affect end users.
- Aids in effective collaboration between stakeholders to address any issues.

f) AI Automation with great visibility

- By gaining clear visibility into essential system metrics, teams can increase their IT automation efforts and execute processes and responses more precisely.



PERSONNEL SECURITY AND MANAGEMENT PRACTICES

- User training and incident reporting
- Third-party access and outsourcing

USER TRAINING AND INCIDENT REPORTING

- User Awareness Training, in the context of cyber security, is a critical component of an organization's overall security strategy.
- It involves educating employees about the various cyber threats they could encounter in their day-to-day activities and how to effectively mitigate these risks.

IMPORTANCE OF USER AWARENESS TRAINING

- It helps in reducing phishing attacks, malware infections, and other forms of cybercrime. By educating employees about the potential risks and the best practices to follow, organizations can significantly reduce their vulnerability to cyber threats.
- User Awareness Training is not just a good security practice, but it is also a regulatory requirement in many industries.
- Compliance with these regulations can help organizations avoid potential legal issues.
- It can also enhance an organization's reputation by demonstrating its commitment to cyber security.

PHISHING AWARENESS

- Phishing is a type of cyber attack where attackers impersonate legitimate organizations or individuals to trick victims into revealing sensitive information. This training helps employees identify phishing emails, understand the risks associated with clicking on suspicious links, and learn how to report potential phishing attempts.
- Phishing Awareness Training often involves simulated phishing attacks where employees receive fake phishing emails.
- This hands-on approach allows employees to apply their knowledge in a safe environment and helps organizations identify areas where additional training may be needed.

SAFE INTERNET BROWSING

- User Awareness Training teaching employees about safe internet browsing practices. This includes educating them about the risks associated with visiting unsecured websites, downloading files from unknown sources, and using public Wi-Fi networks. By adhering to safe browsing practices, employees can significantly reduce the risk of malware infections and other cyber threats.
- Safe Internet Browsing Training often involves practical demonstrations and interactive sessions where employees can learn about various browser security features and how to use them effectively.

COMPONENTS OF USER AWARENESS TRAINING

- User Awareness Training typically comprises several components, each focusing on a specific aspect of cyber security.
- These components are designed to provide a comprehensive understanding of the various cyber threats and the best practices to mitigate them.
- While the exact components may vary depending on the organization's specific needs and the industry it operates in, some of the common components include Phishing Awareness, Safe Internet Browsing, Password Security, Social Engineering Awareness, and Incident Reporting.

PASSWORD SECURITY

- Password Security Training is a crucial part of User Awareness Training.
- It involves educating employees about the importance of strong passwords, the risks associated with password reuse, and the benefits of using password managers.
- This training helps employees understand why password security is important and how they can contribute to enhancing the organization's overall security.

SOCIAL ENGINEERING AWARENESS

- Social engineering is a type of cyber attack where attackers manipulate victims into revealing sensitive information or performing actions that compromise security.
- This training helps employees understand the various tactics used by social engineers and how to avoid falling victim to these attacks.
- Social Engineering Awareness Training often involves real-world examples and case studies .This approach helps employees understand the real-world implications of these attacks and enhances their ability to identify and avoid potential threats.

INCIDENT REPORTING

- Incident Reporting Training is a critical part of User Awareness Training.
- It involves educating employees about the importance of reporting potential security incidents promptly and the correct procedures to follow when reporting an incident.
- This training helps employees understand their role in the organization's incident response plan and enhances their ability to respond effectively to potential security incidents.

IMPLEMENTING USER AWARENESS TRAINING

- Implementing User Awareness Training in an organization involves several steps. These include identifying the training needs, developing the training content, delivering the training, and evaluating the effectiveness of the training. Each of these steps plays a crucial role in ensuring that the training is effective and achieves the desired outcomes.
- While implementing User Awareness Training can be a complex task, it is a worthwhile investment. By empowering employees with the necessary knowledge and skills, organizations can significantly enhance their cyber security posture and reduce their vulnerability to cyber threats.

IMPLEMENTING USER AWARENESS TRAINING

1. Identifying Training Needs

- The first step in implementing User Awareness Training is identifying the training needs.
- Identifying the training needs often involves conducting a risk assessment, surveying employees to understand their current knowledge levels, and consulting with cyber security experts.
- The information gathered during this step forms the basis for developing the training content.

IMPLEMENTING USER AWARENESS TRAINING

2. Developing Training Content

- Once the training needs have been identified, the next step is developing the training content.
- Developing the training content often involves collaborating with cyber security experts, using multimedia elements to enhance engagement, and incorporating practical exercises and simulations to provide hands-on experience.
- The goal is to create a comprehensive training program that not only imparts knowledge but also changes behavior and fosters a culture of security.

IMPLEMENTING USER AWARENESS TRAINING

3.Delivering the Training

- Once the training content has been developed, the next step is delivering the training. This involves conducting the training sessions, facilitating discussions, and providing support to the employees.
- The training should be delivered in a manner that is engaging and interactive to ensure that employees are actively involved in the learning process.
- Delivering the training often involves using a variety of delivery methods, such as classroom training, online training .

IMPLEMENTING USER AWARENESS TRAINING

4.Evaluating Training Effectiveness

- The final step in implementing User Awareness Training is evaluating the effectiveness of the training.
- This involves assessing whether the training has achieved its objectives, whether employees have understood the content, and whether there has been a change in behavior.
- This step is crucial as it helps in identifying areas where additional training may be needed and in making necessary improvements to the training program.

IMPLEMENTING USER AWARENESS TRAINING

- Evaluating the training effectiveness often involves conducting assessments, gathering feedback from employees, and monitoring changes in behavior.
- The information gathered during this step helps in refining the training program and ensuring that it continues to meet the organization's needs.

APPLICATION SOFTWARE CONTROL

- Application software controls are procedures and mechanisms built into computer applications to ensure the accuracy, completeness, validity, and authorization of data during input, processing, and output stages.
- These controls are specific to each application and are crucial for ensuring that the system performs reliably and securely.

SOFTWARE DEVELOPMENT CONTROL

These controls ensure that software is developed in a **controlled and secure manner**, reducing the risk of errors, unauthorized access, or system failure. It involves:

- System development life cycle (SDLC) procedures.
- Change management processes for upgrades or patches.
- Coding standards and documentation requirements.
- Access controls for developers.
- Testing procedures (unit, integration, system, UAT).
- Audit trails for changes in software components.
- These controls aim to ensure that only authorized, tested, and approved software is moved to production.

SOFTWARE DEVELOPMENT CONTROL

Input, Processing and Output Control

- These are transaction-level controls within applications that ensure data is handled correctly from entry to result.

a. Input Controls

- Ensure that the data entered into the system is accurate, complete, and authorized.

Examples:

- Validation checks (e.g., date, numeric range)
- Authorization checks (e.g., user permissions)
- Error messages for invalid input
- Use of pre-numbered forms or batch totals

SOFTWARE DEVELOPMENT CONTROL

b. Processing Controls

Ensure that data is processed **accurately and completely**.

Examples:

- Run-to-run totals
- Sequence checks
- Logic validation
- Data integrity checks

SOFTWARE DEVELOPMENT CONTROL

Output Controls

Ensure that system outputs (reports, files, messages) are correct, secure, and delivered to authorized users.

Examples:

- Report reconciliation
- Access controls for report viewing
- Output logging and monitoring
- Error correction procedures

SOFTWARE DEVELOPMENT CONTROL

Software Development and Maintenance Controls

These ensure that only authorized, tested, and approved programs are used and that any changes are controlled.

● Examples:

- Change management process
- Version control
- Testing and debugging procedures
- Developer access restrictions

SOFTWARE DEVELOPMENT CONTROL

User Access and Authorization Controls

Ensures that only authorized users can access the application and perform permitted functions.

Examples:

- Role-based access control
- Login ID and password
- User activity logs
- Multi-factor authentication

SOFTWARE DEVELOPMENT CONTROL

Purpose of Application Software Controls

- Maintain data integrity
- Ensure accuracy of processing
- Prevent fraud and unauthorized access
- Support auditability and accountability
- Ensure reliable output for decision-making